MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 036 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

Q&A · NIST 800-171

NIST 800-171 Rev 3 vs Rev 2: It Depends Who Signed the Contract

NIST 800-171 Rev 3 vs Rev 2: DoD still binds and scores Rev 2 while civilian CUI heads to Rev 3. What changed, the ID trap, and how to map once.

BY **PATRICK CARUSO**

READING TIME · 7 MIN

NIST-800-171 · REV-3 · DFARS · CMMC · ORGANIZATION-DEFINED-PARAMETERS

NIST retired Revision 2 of SP 800-171 in May 2024, and the Department of Defense declined to follow. More than two years later, that split has produced an odd kind of compliance debt: a contractor who reads the current NIST publication is reading a standard their DoD contract does not require, and the standard the contract does require is one NIST no longer offers as current. Most confusion about the two revisions comes from treating them as versions of one document. They are two documents, bound by two different pens.

The direct answer to NIST 800-171 Rev 3 vs Rev 2 is this. If your CUI obligation arrives through DFARS 252.204-7012 or CMMC, you are bound to Rev 2's 110 requirements, and Rev 2 is what gets scored. If you hold civilian-agency contracts, Rev 3 is where the rulemaking is heading, but it is not yet final. Many firms hold both kinds of work, which is why the useful question is not which revision to pick but how to run one program that answers to each.

FIELD COPY
ISSUE Nº 036
NIST 800 171

97

ACTIVE REQUIREMENTS IN REV 3, OUT OF 130 NUMBERED IDENTIFIERS - 33 ARE WITHDRAWN

88

ORGANIZATION-DEFINED PARAMETERS IN REV 3; REV 2 HAS NONE

422

ASSESSMENT OBJECTIVES IN 800-171A REV 3, AGAINST 320 FOR REV 2

Which revision applies to my contract, NIST 800-171 Rev 3 or Rev 2?

For DoD work, Rev 2, on two independent authorities. Class Deviation 2024-O0013, issued 2 May 2024 and later reissued as Revision 1 to update its links, tells contractors under DFARS 7012 to comply with Rev 2 rather than whichever version is current when a solicitation issues, and it holds until DoD rescinds it. Separately, 32 CFR 170.14 incorporates Rev 2 by reference as the source of the 110 CMMC Level 2 requirements. Rescinding the deviation would not, by itself, move CMMC.

Scoring settles the practical matter. The DoD Assessment Methodology behind every SPRS score is a Rev 2 instrument - its 5, 3, and 1 point weights attach to Rev 2 identifiers, and no Rev 3 edition of those weights exists. The suspension of CMMC Phase II third-party assessments since 13 July changes none of this; 7012 and its Rev 2 baseline remain in force.

Civilian work is heading the other way. The FAR Council's revised CUI proposal, published 23 June 2026, would require contractors handling civilian-agency CUI to meet Rev 3. Comments closed in July and no final rule has issued, so for now it is a direction of travel rather than an obligation - and a separate MacZine issue takes that rule apart on its own terms.

◆ DOD'S OWN MEMO DROPS THE ZERO

The April 2025 DoD memo that sets Rev 3's parameter values heads its sections with numbers like "3.1.1 System Account Management" - a Rev 3 requirement printed in Rev 2's numbering style. If the Department's own document invites the collision, your spreadsheet will too.

What are the NIST 800-171 Rev 3 changes that actually matter?

The headline numbers mislead in the reassuring direction. Rev 3 numbers 130 requirements but withdraws 33, leaving 97 active against Rev 2's 110. Fewer requirements sounds like less work. It is not. Most withdrawals are consolidations into other requirements, and the assessment layer grew: 800-171A Rev 3 carries 422 assessment objectives where Rev 2 had 320. The families went from 14 to 17, adding Planning, System and Services Acquisition, and Supply Chain Risk Management.

That last family is the clearest case of genuinely new work. Rev 3's 03.17.03 requires a process for identifying and addressing weaknesses in supply chain elements and processes, and assessors are pointed at an SCRM plan, purchase orders, and service-level agreements for

evidence. Rev 2 has no supply chain family at all. A DoD contractor with a clean Rev 2 program may have nothing written down that answers it.

Is Rev 3's 03.01.01 the same requirement as Rev 2's 3.1.1?

No, and this is the trap that costs the most because it is invisible. Rev 2's 3.1.1 is one sentence: limit system access to authorized users, processes acting for them, and devices. It carries six assessment objectives and five SPRS points. Rev 3's 03.01.01 is Account Management, an eight-part requirement covering account types, the account lifecycle, monitoring, disabling, notification, and logout, with six organization-defined parameters and 22 assessment objectives.

The collision happens in software. Normalize Rev 2's "3.1.1" to a zero-padded sort key and you get "03.01.01," which silently joins it to the wrong requirement. At the other end of the catalog it gets worse: Rev 2's 3.13.16, protecting CUI at rest, pads to a Rev 3 number that is withdrawn, so a careless join reports an active one-point control as retired.

An identifier without its revision is not a citation. It is a coin toss.

The fix is clerical and absolute. Never store a bare requirement number anywhere - not in the SSP, the POA&M, the evidence folder names, or the GRC tool. Store the revision with it, every time.

What are organization-defined parameters, and why do they change the evidence?

An organization-defined parameter is a blank inside the requirement that someone must fill with a value. Rev 2 has none, and that is the whole difference in evidence burden. Rev 2's 3.1.8 says only "limit unsuccessful logon attempts." Rev 3's 03.01.08 brackets the number of attempts, the time window, and the action taken when the limit is hit. DoD's memo of 10 April 2025 fills them: at most five consecutive invalid attempts in five minutes, then either lock the account for at least 15 minutes, or lock it until an administrator releases it and notify that administrator. The assessor's question moves from "does a limit exist" to "does the configuration match this number."

Cryptography shows why the values matter more than the sentences. Rev 2's 3.13.11 names FIPS-validated cryptography in the requirement itself, worth up to five SPRS points. Rev 3's 03.13.11 replaces that phrase with a parameter, "types of cryptography," and NIST's discussion merely recommends FIPS validation. DoD's value restores it: FIPS-validated cryptography, pointed at the NIST validated-modules list. Read raw from NIST, Rev 3 is weaker than Rev 2 on this point; read with DoD's parameters, it is not. A contractor who builds to Rev 3 from the NIST page alone could build something DoD would not accept.

The memo is candid about its purpose, describing its values as set "in preparation to implement reference (a) as the minimum requirement for contractors," and it defines four of the 88 parameters as guidance rather than a fixed value. Rev 3 is coming to DoD on a date nobody has set. The parameters are the preview.

Is there an 800-171 Rev 3 crosswalk that lets me map once?

There is a crosswalk, but it is not a lookup table, because the relationship is many-to-many. Rev 2's 3.4.9, controlling user-installed software, has no single successor: Rev 3 withdraws 03.04.09 and spreads its substance across five requirements, 03.01.05, 03.01.06, 03.01.07, 03.04.08, and 03.12.03. Rev 2's 3.1.13, cryptographic protection of remote access sessions and a five-point control, fares the same way: Rev 3 withdraws 03.01.13 into 03.13.08, which covers CUI in transmission and in storage in one sentence and, unlike Rev 2's 3.13.8, makes no allowance for alternative physical safeguards.

"Map once" therefore means mapping implementations, not identifiers. Keep one record per thing you actually do - the lockout policy, the encryption configuration - and tag it with every Rev 2 and Rev 3 requirement it satisfies, revision-prefixed, with the parameter value it enforces. The documentation discipline is the one we laid out for scoping a Level 2 document set, with one added column. MacTech's CMMC MCP server exposes `crosswalk_revisions` and `lookup_rev3_requirement` tools that return both statements side by side and flag the collisions, which is how the examples in this piece were checked.

Should I implement Rev 3 now or keep building to Rev 2?

Build and score to Rev 2 for anything DoD touches. That is what posts to SPRS and what an assessor will test, and a Rev 3 supply chain plan earns nothing against an open five-point Rev 2 gap.

But where Rev 2 leaves a number to you, pick DoD's Rev 3 value and write it into the SSP as a deliberate design decision, with the rationale beside it. Rev 2 says limit logon attempts; choosing five in five minutes satisfies Rev 2 today and answers 03.01.08 before anyone asks. Across a program, those choices turn a future migration from a rebuild into a review. MacTech's NIST 800-171 compliance page covers where that program work starts.

So it does depend who signed the contract, though less than the title suggests. For a defense contractor this autumn, the right standard is Rev 2 with Rev 3's numbers already written in the margin. ◆

MORE ISSUES

mactechsolutionsllc.com/maczine

new field copies with every merge

WORK WITH US

CMMC readiness · CUI enclaves · RMF

mactechsolutionsllc.com/contact

MACZINE

Written, reviewed and versioned in the open.

Published from Git, reviewed like code.